



LOST BOYS CYBER

THREAT INTELLIGENCE • MALWARE ANALYSIS • DETECTION ENGINEERING



CVE-2026-42271 BerriAI LiteLLM authenticated command execution via MCP stdio test endpoints

CVE / Vulnerability Threat Intelligence Report

Classification	TLP:CLEAR
Published	2026-06-08
Version	1.1
Author	Lost Boys Cyber
Report Type	CVE / Vulnerability Threat Intelligence Report

TLP:CLEAR | Lost Boys Cyber | CVE-2026-42271 BerriAI LiteLLM authenticated command execution via MCP stdio test endpoints -
CVE / Vulnerability Threat Intelligence Report

Published: 2026-06-08 | TLP:CLEAR | Version: 1.1 | Author: Lost Boys Cyber

AI Generation: This report was generated with AI assistance and is provided for informational purposes only. All findings, IOCs, detection rules, hunting queries, attribution assessments, and recommendations must be independently reviewed and validated by a qualified security professional before operational use.

Table of Contents

1. Executive Summary
2. Vulnerability Metadata
3. Source Review & Confidence
4. Vulnerability Details
5. Attack Scenarios
6. Threat Landscape & Exploitation Status
7. Affected Products and Exposure
8. Mitigation and Workarounds
9. Detection Engineering
10. Threat Hunting
11. MITRE ATT&CK Mapping
12. Validation / Lab Testing
13. Recommended Actions Summary
14. References

CVE-2026-42271 BerriAI LiteLLM authenticated command execution via MCP stdio test endpoints

1. Executive Summary

CVE-2026-42271 is a high-severity command-execution vulnerability in BerriAI LiteLLM, an AI gateway/proxy used to broker requests to multiple LLM providers. The affected MCP preview endpoints accepted attacker-controlled ``command``, ``args``, and ``env`` values for stdio transport testing, then executed those values as a subprocess on the proxy host.

In the baseline advisory, exploitation requires any valid LiteLLM proxy API key and does not require an administrator role. That still creates serious operational risk because low-privilege internal-user keys are sufficient, and successful exploitation runs with the privileges of the LiteLLM proxy process. In default containerized deployments discussed by third-party researchers, that may mean root inside the container.

This issue matters for defenders because it combines three escalation themes: exposed AI gateway infrastructure, weak separation between low-privilege and administrative actions, and public evidence of growing exploit interest. GitHub's advisory and NVD describe the flaw directly, CISA added it to the Known Exploited Vulnerabilities (KEV) catalog on 2026-06-08, and public research indicates the bug may be chainable with a Starlette host-header bypass to remove the authentication requirement entirely in some deployments.

2. Vulnerability Metadata

Field	Value
CVE	<code>`CVE-2026-42271`</code>
GHSA	<code>`GHSA-v4p8-mg3p-g94g`</code>
Product / component	BerriAI LiteLLM proxy, MCP stdio test endpoints
Affected endpoints	<code>`POST /mcp-rest/test/connection`</code> and <code>`POST /mcp-rest/test/tools/list`</code>
Vulnerable behavior	preview endpoints accept a full MCP server configuration and spawn attacker-supplied commands while testing stdio connectivity
Weaknesses	<code>`CWE-77`</code> and <code>`CWE-78`</code>
Severity	High
GitHub CVSS v4	<code>`8.7`</code>
NVD CVSS v3.1 vector	<code>`AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H`</code> (8.8 / HIGH)
Affected versions	<code>`>= 1.74.2, < 1.83.7`</code>
Patched version	<code>`1.83.7`</code> / <code>`v1.83.7-stable`</code>
Original advisory publication	<code>`2026-04-21`</code> (GitHub Security Advisory)
NVD publication	<code>`2026-05-08`</code>
CISA KEV date added	<code>`2026-06-08`</code>

3. Source Review & Confidence

Source	Contribution	Confidence
Reviewed source	CISA KEV lists CVE-2026-42271 as 'BerriAI LiteLLM Command Injection Vulnerability', states any authenticated user includ	Strongest public source for exploitation-in-the-wild prioritization.
Reviewed source	Primary advisory identifies affected versions `>= 1.74.2, < 1.83.7`, the impacted endpoints `/mcp-rest/test/connection`	Primary technical source tied directly to `BerriAI/litellm`.
Reviewed source	NVD mirrors the vulnerable-version range, endpoint behavior, subprocess-spawn impact, and `CWE-77` / `CWE-78` mapping; t	Strong corroborating source for severity and structured metadata.
Reviewed source	The patched release referenced by the advisory is `v1.83.7-stable`.	Primary release-validation source for remediation targeting.
Reviewed source	runZero summarizes CVE-2026-42271 alongside other LiteLLM flaws, notes that official container images may run the proxy	Good operational source for defender context; not the primary source for core vulnerability mechanic
Reviewed source	Horizon3.ai states CVE-2026-42271 can be chained with `CVE-2026-48710` to produce unauthenticated RCE in some vulnerable	Valuable chain-analysis context, but third-party and not independently reproduced during this review
Reviewed source	Public PoC repository advertises reproducible exploitation against LiteLLM `v1.82.6`, describes authenticated command in	Useful indicator of public weaponization interest; treat reproduction claims as unvalidated unless t

Confidence is high on the core finding because the strongest available sources align on impact, affected versions, and the fix path: Confidence is lower on broader chaining and exploitation tradecraft details because those claims come from third-party research rather than the vendor advisory itself. Horizon3.ai publicly states that CVE-2026-42271 can be chained with `CVE-2026-48710` to bypass authentication entirely in LiteLLM deployments whose dependency tree includes vulnerable Starlette versions. That claim is plausible and operationally important, but it was not independently reproduced during this review. Public PoC repositories also indicate active researcher and offensive interest, which should increase defender urgency even when local reproduction has not been performed.

4. Vulnerability Details

LiteLLM includes endpoints that let operators preview an MCP server configuration before saving it. For stdio-based MCP servers, that configuration includes the executable path, arguments, and environment variables used to launch the subprocess.

In vulnerable versions, `POST /mcp-rest/test/connection` and `POST /mcp-rest/test/tools/list` accept that configuration directly from the caller and immediately attempt the connection test. When the supplied transport is stdio, LiteLLM spawns the supplied command on the proxy host with the privileges of the LiteLLM process.

The security boundary failure is authorization, not just input handling. The endpoints required only a valid proxy API key and did not enforce the `PROXY\_ADMIN` role that would normally be expected for an operation capable of launching new processes on the host. That means any authenticated user with a lower-privilege internal-user key could cross from ordinary proxy usage into host-level command execution.

If the LiteLLM process has broad host or container privileges, the impact can include credential exposure, process tampering, persistence staging, lateral movement preparation, and complete compromise of the gateway node.

5. Attack Scenarios

1. An attacker compromises or steals any valid LiteLLM proxy API key, then submits a crafted stdio MCP preview request to execute arbitrary shell commands on the proxy host.
2. A malicious insider or low-privilege internal user abuses legitimate key access to run unauthorized commands through the test endpoints.
3. A defender overlooks the risk because the endpoint appears to be an administrative preview function, while the actual authorization logic only checks for a valid proxy key.
4. In deployments matching Horizon3.ai's chain analysis, an attacker first abuses `CVE-2026-48710` to bypass host-header-based protections and then reaches the LiteLLM command-execution path without valid credentials.
5. In default container deployments where the LiteLLM process runs as root, an attacker gains immediate high-privilege execution inside the container and can pivot into secrets, model credentials, or orchestration control paths.

6. Threat Landscape & Exploitation Status

- CISA KEV inclusion is the strongest public signal in this review that real-world exploitation has occurred.
- GitHub and NVD both rate the issue as high severity and describe low-privilege authenticated command execution with direct host impact.
- runZero notes that CVE-2026-42271 was disclosed alongside other LiteLLM vulnerabilities that can form an attack chain, increasing the chance of opportunistic exploitation against exposed AI gateway deployments.
- Public PoC material exists for this vulnerability, which lowers reproduction barriers for attackers and defenders alike.
- Third-party research from Horizon3.ai argues that authentication can be bypassed entirely in some dependency combinations, effectively converting the issue from authenticated command execution into unauthenticated remote code execution. Treat that scenario as high-priority exposure validation rather than as a universally proven condition across all LiteLLM installations.

7. Affected Products and Exposure

Directly affected products are LiteLLM proxy deployments running versions `1.74.2` through `1.83.6` that expose the MCP stdio preview endpoints.

Higher-risk patterns:

- Internet-reachable LiteLLM proxies.
- Deployments where many users or services hold valid proxy API keys.
- Environments using internal-user keys under the assumption they cannot trigger administrative actions.
- Official or similar containerized deployments where the LiteLLM process runs with elevated privileges.
- AI gateway nodes that store provider API keys, internal secrets, model routing policy, or customer traffic metadata.
- Deployments whose dependency tree also includes the Starlette host-header bypass conditions described by Horizon3.ai.

Lower-risk patterns:

- LiteLLM instances upgraded to `1.83.7` or later.
- Proxies with the vulnerable test endpoints blocked upstream at a reverse proxy or API gateway.
- Deployments where MCP preview functionality is not exposed and where API key issuance is tightly restricted and monitored.

8. Mitigation and Workarounds

Priority actions:

6. Upgrade LiteLLM to `v1.83.7-stable` or later immediately.
7. If emergency patching is not yet possible, block `POST /mcp-rest/test/connection` and `POST /mcp-rest/test/tools/list` at the reverse proxy, API gateway, WAF, or ingress layer.

8. Audit all LiteLLM proxy API keys, especially low-privilege internal-user keys, and rotate any keys that cannot be fully accounted for.
9. Review whether the LiteLLM process runs as root or with excessive container privileges; reduce runtime privileges wherever possible.
10. Validate whether the deployment also carries the Starlette host-header bypass exposure discussed in public research and patch those dependencies as part of the same emergency response window.
11. Review provider credentials, secrets, and logs on potentially affected hosts for evidence of post-exploitation.

9. Detection Engineering

Detection priorities should focus on exposed endpoints, key misuse, and subprocess execution from the LiteLLM service context:

Signal	Telemetry Source	Analytic Goal
Alert on requests to `/mcp-rest/test/connection` and `/mcp-rest/test/tools/list`, especially from non-admin users, unusual source IPs, or service accounts that normally only proxy inference traffic.	Asset inventory / service / security telemetry	Identify vulnerable systems, exposure, or suspicious follow-on activity
Log and review request bodies that contain stdio transport definitions, especially unexpected `command`, `args`, and `env` fields.	Asset inventory / service / security telemetry	Identify vulnerable systems, exposure, or suspicious follow-on activity
Monitor LiteLLM hosts and containers for child-process creation from the LiteLLM service, web process, or container endpoint.	Asset inventory / service / security telemetry	Identify vulnerable systems, exposure, or suspicious follow-on activity
Hunt for shell launches, scripting interpreters, network utilities, package managers, or outbound connections spawned immediately after requests to the MCP test endpoints.	Network, auth, proxy, or service-access logs	Identify externally reachable or suspiciously accessed systems
Review auth logs and key-usage telemetry for internal-user keys accessing administrative-looking API paths.	Asset inventory / service / security telemetry	Identify vulnerable systems, exposure, or suspicious follow-on activity

9.1 Detection Query

```
// Internet-facing service inventory and version-discovery pivots for CVE-2026-42271 BerriAI LiteLLM
authenticated command execution via MCP stdio test endpoints
DeviceProcessEvents
| where Timestamp > ago(30d)
| where ProcessCommandLine has_any ("weblogic", "panos", "litellm", "docker ps", "kubectl get pods")
| project Timestamp, DeviceName, FileName, ProcessCommandLine
| order by Timestamp desc
```

9.2 Exposure / Triage Query

```
// External exposure and suspicious follow-on activity
DeviceNetworkEvents
| where Timestamp > ago(30d)
| where RemotePort in (80, 443, 8080, 8443)
```

```
| project Timestamp, DeviceName, InitiatingProcessFileName, LocalIP, RemoteIP, RemotePort, RemoteUrl
| order by Timestamp desc
```

10. Threat Hunting

Suggested hunt questions:

- Which LiteLLM instances in the environment are below `1.83.7`?
- Which of those instances expose MCP preview endpoints to the internet, shared internal networks, or untrusted tenants?
- Have any non-admin users or service accounts called `/mcp-rest/test/connection` or `/mcp-rest/test/tools/list`?
- Do process trees on LiteLLM hosts show child processes that do not match expected MCP connectors?
- Were any LiteLLM provider secrets, internal API tokens, or cloud credentials accessed or rotated shortly after suspicious MCP test requests?
- Are any deployments simultaneously vulnerable to the Starlette host-header bypass chain described by Horizon3.ai?

10.1 Hunt Query

```
// External exposure and suspicious follow-on activity
DeviceNetworkEvents
| where Timestamp > ago(30d)
| where RemotePort in (80, 443, 8080, 8443)
| project Timestamp, DeviceName, InitiatingProcessFileName, LocalIP, RemoteIP, RemotePort, RemoteUrl
| order by Timestamp desc
```

11. MITRE ATT&CK Mapping

Two ATT&CK techniques are supportable at high confidence for exploitation activity against exposed LiteLLM deployments:

- `T1190` Exploit Public-Facing Application: the vulnerable MCP preview endpoints can be reached over the network and abused to cross from application access into command execution on the host.
- `T1059` Command and Scripting Interpreter: successful exploitation causes the target to execute attacker-supplied commands as subprocesses.

If the Horizon3.ai chain condition is present, `T1190` becomes even more relevant because the authentication boundary can be bypassed before command execution. Additional post-exploitation ATT&CK mapping would depend on what the attacker does after landing on the host and is therefore outside the strongest evidence base for this intake review.

12. Validation / Lab Testing

This review validated the report against publicly available advisories and research rather than reproducing the exploit in a local LiteLLM lab. Analyst validation steps completed:

- Reviewed the CISA KEV catalog entry that triggered the intake.
- Reviewed GitHub advisory `GHSA-v4p8-mg3p-g94g` for the authoritative affected-version range, endpoint names, patch description, and workaround guidance.
- Reviewed NVD for corroborating vulnerability text, CWE mappings, CVSS vectors, and reference linkage.
- Reviewed the patched release reference `v1.83.7-stable` as the primary upgrade target.
- Reviewed runZero's exposure note for deployment and detection context.
- Reviewed Horizon3.ai's public chain analysis for the potential unauthenticated exploitation path.
- Confirmed public PoC discoverability during source expansion.

No Lost Boys Cyber proof-of-concept execution was performed during this report review, and no claim is made here that the Horizon3.ai chain or public PoC was independently reproduced.

13. Recommended Actions Summary

Priority	Owner	Action
Critical	Platform / Application Owners	Patch all LiteLLM proxy deployments to

		`1.83.7` or later on an emergency basis.
Critical	Platform / Application Owners	Block the two vulnerable MCP preview endpoints at the edge until every deployment is verified patched.
High	Security / Platform Owners	Treat any exposed LiteLLM instance with uncertain key hygiene as potentially compromised because low-privilege keys are sufficient in the baseline advisory.
High	SOC / Detection Engineering	Investigate LiteLLM process trees, logs, and secret access for signs of command execution or post-exploitation.
High	Security / Platform Owners	Reduce runtime privileges for LiteLLM containers and services so future application flaws do not translate directly into high-impact host execution.
High	Security / Platform Owners	Validate adjacent dependency exposure, especially the public Starlette bypass chain claims, before concluding the environment is safe.

14. References

12. CISA Known Exploited Vulnerabilities Catalog, `CVE-2026-42271`
13. GitHub Advisory Database, `GHSA-v4p8-mg3p-g94g`
14. NVD, `CVE-2026-42271`
15. BerriAI LiteLLM patched release, `v1.83.7-stable`
16. runZero, `LiteLLM Proxy vulnerabilities: How to find impacted assets`
17. Horizon3.ai, `CVE-2026-42271 Chained with CVE-2026-48710`
18. Public PoC repository, `learner202649/CVE-2026-42271-PoC`